

Guía Metodológica Detallada – Encuesta VAST Nacional (España)

Versión 1.0 – Abril 2026

1. Objetivo de la encuesta

La encuesta VAST Nacional tiene como objetivo:

- Obtener una radiografía cuantitativa y cualitativa del grado de madurez en modelado de amenazas y métricas de ciberseguridad en organizaciones españolas.
- Identificar brechas y áreas prioritarias de mejora en:
 - Gobernanza y cumplimiento normativo.
 - Inventario de activos y superficie de ataque.
 - Modelado de amenazas (VAST, STRIDE, PASTA, etc.).
 - Métricas operativas, de riesgo y de negocio.
 - Gestión de vulnerabilidades y terceros.
 - Respuesta, continuidad y resiliencia.
 - Talento, cultura y prioridades de inversión.
- Generar un Índice Global de Madurez (IGM) comparable entre organizaciones y sectores, y una base para análisis de ROI de las medidas de ciberseguridad.

2. Población objetivo y criterios de segmentación

2.1. Población objetivo

- Operadores de servicios esenciales definidos por la normativa NIS2 y su transposición en España.
- Operadores de infraestructuras críticas.
- Entidades financieras sometidas a DORA y a supervisores nacionales.
- Organismos públicos (estatal, autonómico y local) con competencias relevantes.
- Grandes empresas y organizaciones de sectores estratégicos (telco, industria, educación, etc.).

2.2. Segmentación

Las respuestas se agruparán según:

- Sector (energía, sanidad, transporte, etc.).
- Tipo de organización (pública / privada, regulada / no regulada).
- Tamaño (micro, pequeña, mediana, grande, muy grande).
- Rol de la persona que responde (CISO, CIO, etc.).

Esta segmentación permitirá comparar perfiles de madurez y prioridades entre grupos.

3. Diseño del cuestionario

3.1. Estructura general

El cuestionario se estructura en 10 bloques:

1. Información general.
2. Gobernanza y estrategia.
3. Inventario de activos y superficie de ataque.
4. Modelado de amenazas.
5. Indicadores y métricas.
6. Vulnerabilidades, exposición y terceros.
7. Respuesta, continuidad y resiliencia.
8. Talento, cultura y formación.
9. Visión de futuro y prioridades.
10. Comentarios finales.

3.2. Tipos de pregunta

- Preguntas cerradas de opción única (p. ej., nivel de cumplimiento).
- Preguntas cerradas de opción múltiple (p. ej., marcos de referencia utilizados).
- Preguntas de escala Likert (1-5) para medir percepciones y grado de madurez.
- Preguntas abiertas para comentarios cualitativos.

Las respuestas cerradas facilitan la construcción de indicadores cuantitativos; las abiertas aportan contexto y matices.

4. Construcción del Índice Global de Madurez (IGM)

4.1. Enfoque general

El IGM mide la madurez de la organización en una escala, por ejemplo, de 0 a 100 puntos, agregando puntuaciones parciales de los bloques clave:

- Gobernanza y cumplimiento (GOV).
- Inventario y superficie de ataque (INV).
- Modelado de amenazas (THR).
- Métricas y riesgo (MET).
- Vulnerabilidades y terceros (VUL).
- Respuesta y continuidad (RES).
- Talento y cultura (TAL).

$$\text{IGM} = w_{\text{GOV}} \cdot \text{GOV} + w_{\text{INV}} \cdot \text{INV} + w_{\text{THR}} \cdot \text{THR} + w_{\text{MET}} \cdot \text{MET} + w_{\text{VUL}} \cdot \text{VUL} + w_{\text{RES}} \cdot \text{RES} + w_{\text{TAL}} \cdot \text{TAL}$$

Con pesos w_x que se podrán ajustar por consenso de expertos (por defecto, peso uniforme o ligeramente superior para THR, MET y RES).

4.2. Ejemplo de ponderación inicial

- GOV: 15 %
- INV: 10 %
- THR: 20 %
- MET: 15 %
- VUL: 15 %
- RES: 15 %
- TAL: 10 %

La ponderación deberá revisarse en un comité técnico.

4.3. Escala de madurez

Propuesta de niveles:

- 0–19: Inicial / reactivo.
- 20–39: Básico.
- 40–59: Intermedio.
- 60–79: Avanzado.
- 80–100: Excelente / líder.

Cada nivel se describirá con un relato comprensible para la dirección y los reguladores.

5. Asignación de puntuaciones por pregunta

5.1. Ejemplos ilustrativos

Para cada pregunta cerrada se definirá una escala numérica. A modo de ejemplo:

P1. Estrategia formal de ciberseguridad

- Aprobada y vigente, revisión anual: 4 puntos.
- Aprobada, sin revisión reciente: 3 puntos.
- Borrador informal: 2 puntos.
- No existe: 0 puntos.
- No sabe: sin puntuación (o imputación conservadora).

P9. Modelado de amenazas aplicado

- Sistemático en la mayoría de sistemas críticos: 4 puntos.
- Solo en proyectos de alta visibilidad: 3 puntos.
- En piloto / experimental: 2 puntos.
- Conocido pero no aplicado: 1 punto.
- Desconocido: 0 puntos.

Se recomienda que cada bloque tenga una puntuación máxima homogénea (por ejemplo, 20 puntos), y que las preguntas se ponderen en función de su relevancia.

5.2. Tratamiento de respuestas “No sabe / no responde”

Opciones:

- Asignar puntuación 0 (enfoque prudente).
- Tratar como dato faltante y normalizar sobre las preguntas respondidas.
- Aplicar reglas mixtas dependiendo de la criticidad de la pregunta.

La elección debe documentarse para evitar sesgos no deseados.

6. Cálculo del ROI (retorno de inversión)

6.1. Concepto

Se propone un cálculo de ROI centrado en:

- Beneficios: reducción estimada de pérdidas por incidentes, mejora en cumplimiento, evitación de sanciones y reducción de interrupciones de negocio.
- Costes: inversiones directas en tecnologías, personal, servicios externos y formación.

$$\text{ROI (\%)} = (\text{Beneficio estimado} - \text{Coste total}) / \text{Coste total} \times 100$$

Los datos necesarios se recogerán en un formulario complementario o mediante entrevistas, más que en el cuestionario base (para no disparar la longitud).

6.2. Conexión con el IGM

Se puede correlacionar la evolución del IGM con:

- Frecuencia y gravedad de incidentes.
- Pérdidas económicas asociadas.
- Multas / sanciones.
- Percepción de riesgo por parte de la dirección.

Esto permite observar si, al aumentar la madurez (IGM), se materializan beneficios tangibles (reducción de pérdidas o riesgos evitados).

7. Proceso de recogida de datos

7.1. Canales y formato

- Encuesta online (preferible) mediante plataforma segura.
- Alternativamente, cuestionario en formato PDF / Word con posterior volcado a Excel.
- Entrevistas estructuradas para entidades clave (muestra cualitativa).

7.2. Garantías de confidencialidad

- Agregación de resultados por sector y tamaño; no se publicarán datos identificables.
- Posibilidad de compartir a cada organización un informe individual comparado (benchmark) de forma confidencial.
- Consentimiento explícito sobre el uso de datos.

8. Validación y pilotos

Antes del despliegue masivo:

- Realizar un piloto con un conjunto reducido de organizaciones de distintos sectores.
- Evaluar:
- Claridad de las preguntas.
- Tiempo promedio de cumplimentación.
- Coherencia de resultados.
- Ajustar redacción, escalas y ponderaciones.

9. Análisis y presentación de resultados

9.1. Análisis cuantitativo

- Cálculo de IGM por organización, sector y tamaño.
- Distribuciones y estadísticas descriptivas (media, mediana, desviación).
- Identificación de “top performers” y “cola larga”.

9.2. Análisis cualitativo

- Análisis temático de comentarios abiertos.
- Identificación de patrones narrativos (puntos de dolor, barreras, buenas prácticas).

9.3. Visualización

- Gráficos de radar para bloques de madurez.
- Mapas de calor por sector y tamaño.
- Series temporales si se repite la encuesta en años sucesivos.

10. Uso responsable de los resultados

La encuesta no pretende ser un examen ni un mecanismo punitivo, sino:

- Una herramienta diagnóstica.
- Un indicador de dónde conviene invertir mejor.
- Un mecanismo para alinear diálogo entre técnicos, gestores y reguladores.

Se recomienda acompañar los resultados de recomendaciones concretas y realistas, evitando tanto el alarmismo fácil como la complacencia.